Northwind BMS REST API

เอกสารสำหรับ API ที่ใช้รูปแบบ REST และ JWT Bearer ตามแนวทาง PJ2

Base URL

```
https://northwindbms.site.je/api/v1
```

Local MAMP example:

```
http://localhost/pj3/api/v1
```

API ตอบกลับเป็น JSON รูปแบบมาตรฐาน:

```
{
  "status": true,
  "data": {}
}
```

เมื่อเกิดข้อผิดพลาด:

```
{
  "status": false,
  "message": "รายละเอียดข้อผิดพลาด"
}
```

การตั้งค่าก่อนใช้งาน

เซิร์ฟเวอร์ต้องเปิดใช้ PHP PDO MySQL และ Apache mod_rewrite เพื่อรองรับการเชื่อมต่อฐานข้อมูลและ URL แบบ REST

1. คัดลอก `api/config.example.php` เป็น `api/config.local.php` แล้วตั้ง host, database, username และ password ให้ตรงกับฐานข้อมูลของโฮสต์
2. ตั้งค่า `jwt_secret` เป็นค่าสุ่มส่วนตัวอย่างน้อย 32 ตัวอักษร หรือกำหนด environment variable `JWT_SECRET` และกำหนด `token_ttl` เป็นวินาที
3. สร้าง secret แบบสุ่มด้วยคำสั่งนี้ แล้วเก็บไว้ใน server config เท่านั้น

```
php -r "echo bin2hex(random_bytes(32));"
```

ห้ามเผยแพร่ฐานข้อมูลหรือ JWT secret ไฟล์ `config.local.php` ไม่รวมอยู่ใน ZIP สำหรับ deploy และถูกปิดกั้นการเข้าถึงผ่านเว็บ

Authentication

ตรวจสอบว่าต้องตั้งค่าผู้ดูแลระบบครั้งแรกหรือไม่

`GET /auth/status` เป็น public endpoint และตอบกลับ `data.setup_required`

สร้างผู้ดูแลระบบคนแรก

`POST /auth/setup` ใช้ได้เฉพาะเมื่อยังไม่มีผู้ใช้ในตาราง `users`:

```
{
  "username": "admin",
  "password": "รหัสผ่านอย่างน้อย 10 ตัวอักษร",
  "display_name": "ผู้ดูแลระบบ"
}
```

ตอบกลับ `201` พร้อม JWT และข้อมูลผู้ใช้

เข้าสู่ระบบ

`POST /auth/login` ไม่ต้องใช้ token:

```
Content-Type: application/json
```

```
{
  "username": "ชื่อผู้ใช้",
  "password": "รหัสผ่าน"
}
```

เมื่อสำเร็จ (`200`):

```
{
  "status": true,
  "data": {
    "token": "<JWT_TOKEN>",
    "user": {
      "id": 1,
      "username": "admin",
      "display_name": "ผู้ดูแลระบบ",
      "role": "admin"
    }
  }
}
```

ใช้ token จริงจาก `data.token` กับทุก endpoint ที่ต้องเข้าสู่ระบบ:

```
Authorization: Bearer <JWT_TOKEN>
```

Token หมดอายุตาม `token_ttl` ใน config (ค่าแนะนำ 28,800 วินาที หรือ 8 ชั่วโมง) API นี้ใช้ Bearer token จึงไม่ใช้ PHP session cookie หรือ CSRF token สำหรับ `/api/v1` ผู้ใช้ client-side logout ได้โดยลบ token; token ที่ออกไปแล้วจะใช้ได้จนกว่าจะหมดอายุหรือมีการเปลี่ยน JWT secret

ดูผู้ใช้ปัจจุบัน

`GET /auth/me` — ต้องส่ง Bearer token

ลงทะเบียนผู้ดูแลระบบเพิ่ม

`POST /auth/register` — ต้องส่ง Bearer token และ body รูปแบบเดียวกับ `/auth/setup` ทุกบัญชีมีสิทธิ์ผู้ดูแลระบบ

เปลี่ยนรหัสผ่าน

`POST /auth/change-password` — ต้องส่ง Bearer token:

```
{
  "old_password": "รหัสผ่านเดิม",
  "new_password": "รหัสผ่านใหม่อย่างน้อย 10 ตัวอักษร"
}
```

ออกจากระบบ

`POST /auth/logout` — ต้องส่ง Bearer token แล้วลบ token ออกจาก client การออกจากระบบจะไม่เพิกถอน token ที่ถูกคัดลอกไปแล้วจนกว่า token จะหมดอายุ

Resource endpoints

ทุก resource ต้องส่ง Bearer token:

Method	Path	รายละเอียด
`GET`	`/{resource}`	อ่านรายการ รองรับ pagination, search, sort
`GET`	`/{resource}/{id}`	อ่านรายการเดียว
`POST`	`/{resource}`	สร้างรายการ
`PUT` / `PATCH`	`/{resource}/{id}`	แก้ไขเฉพาะฟิลด์ที่ส่ง
`DELETE`	`/{resource}/{id}`	ลบรายการเมื่อไม่มีข้อมูลอื่นอ้างอิง

Resource ที่รองรับ: `products`, `categories`, `customers`, `suppliers`, `employees`, `shippers`

Query สำหรับรายการ

Parameter	Default	ข้อกำหนด
`page`	`1`	หน้าที่ต้องการ เริ่มที่ 1
`limit`	`20`	จำนวนต่อหน้า 1–100
`search`	ว่าง	ค้นหาชื่อหรือรหัสตาม resource
`sort`	`desc`	`asc` เรียงรหัสจากน้อยไปมาก; ค่าอื่นเรียงจากมากไปน้อย

ตัวอย่าง:

```
GET /products?page=1&limit=20&search=chai&sort=asc
Authorization: Bearer <JWT_TOKEN>
```

Response มี `data` เป็น array และ `meta.page`, `meta.limit`, `meta.total`

ฟิลด์สร้าง/แก้ไข

เมื่อสร้าง `POST` ต้องระบุฟิลด์ที่จำเป็นทั้งหมด ฟิลด์อื่นที่ไม่ได้ระบุจะไม่ถูกแก้ไขใน `PUT` / `PATCH`

Resource	JSON fields
`products`	`product_name` string สูงสุด 30 ตัวอักษร *, `supplier_id` integer *, `category_id` integer *, `quantity_per_unit` string สูงสุด 30 ตัวอักษร *, `unit_price` number *
`categories`	`category_name` string สูงสุด 30 ตัวอักษร *, `description` string สูงสุด 30 ตัวอักษร *
`customers`	`company_name` string สูงสุด 50 *, `contact_name` string สูงสุด 50 *, `address` string *, `city` string สูงสุด 50 *, `postal_code` string สูงสุด 30 *, `country` string สูงสุด 50 *
`suppliers`	`company_name`, `contact_name`, `address`, `city`, `postal_code`, `country`, `phone` เป็น string สูงสุด 30 ตัวอักษร และจำเป็นทุกฟิลด์
`employees`	`first_name`, `last_name`, `birth_date`, `photo`, `notes` เป็น string และจำเป็นทุกฟิลด์; จำกัดความยาวตาม schema ฐานข้อมูล
`shippers`	`company_name` string สูงสุด 30 *, `phone` string สูงสุด 30 *

`*` จำเป็นเมื่อสร้างรายการ ค่า `supplier_id` และ `category_id` ต้องอ้างถึงข้อมูลที่มีอยู่จริง รหัสของรายการสร้างโดย API

ตัวอย่าง `POST /products`:

```
{
  "product_name": "สินค้าใหม่",
  "supplier_id": 1,
  "category_id": 1,
  "quantity_per_unit": "10 กล่อง",
  "unit_price": 25.5
}
```

Orders

Method	Path	รายละเอียด
`GET`	`/orders`	อ่านรายการคำสั่งซื้อ พร้อม pagination
`POST`	`/orders`	สร้างคำสั่งซื้อและรายการสินค้าใน transaction เดียว
`GET`	`/orders/{id}`	อ่านคำสั่งซื้อพร้อมรายการสินค้า
`PUT`	`/orders/{id}`	แก้ไขลูกค้า พนักงาน บริษัทขนส่ง หรือวันที่
`PATCH`	`/orders/{id}`	ตอบ `422` เพราะ schema นี้ไม่มีสถานะ/วันที่จัดส่ง
`DELETE`	`/orders/{id}`	ลบรายการสินค้าและคำสั่งซื้อใน transaction เดียว
`GET`	`/orders/{id}/items`	อ่านรายการสินค้าในคำสั่งซื้อ

`GET /orders` รองรับ `page`, `limit`, `search`, `sort`; เพิ่มตัวกรอง `status` (`มีรายการสินค้า` หรือ `ไม่มีรายการสินค้า`), `from`, `to` (`YYYY-MM-DD`) ได้

Request `POST /orders`:

```
{
  "customer_id": 1,
  "employee_id": 1,
  "ship_via": 1,
  "order_date": "2026-10-31",
  "items": [
    {
      "product_id": 1,
      "quantity": 2
    }
  ]
}
```

`customer_id`, `employee_id`, `ship_via`, `order_date` และ `items` จำเป็น ต้องใช้รหัสที่มีอยู่จริง จำนวนสินค้าเป็น integer ตั้งแต่ 1 ขึ้นไป วันที่ใช้รูปแบบ `YYYY-MM-DD`

Reports

`GET /reports/summary` — ต้องส่ง Bearer token ส่งกลับ `summary`, `top_products`, `top_customers`, `top_employees` จากข้อมูล Northwind รองรับ `year=YYYY` เพื่อเลือกปี หรือ `year=all` เพื่อดูทุกปี

Response status

HTTP status	ความหมาย
`200`	สำเร็จ
`201`	สร้างข้อมูลสำเร็จ
`400`	request หรือ ID ไม่ถูกต้อง
`401`	ไม่มี token, token ไม่ถูกต้อง/หมดอายุ หรือข้อมูลล็อกอินไม่ถูกต้อง
`404`	ไม่พบ endpoint หรือรายการ
`409`	ข้อมูลซ้ำหรือมีข้อมูลอื่นอ้างอิง
`422`	ข้อมูลไม่ครบหรือไม่ผ่าน validation
`503`	การตั้งค่าฐานข้อมูลหรือ JWT ยังไม่พร้อม

Postman

1. เรียก `POST https://northwindbms.site.je/api/v1/auth/login` ด้วย body แบบ JSON 2. คัดลอก `data.token` จาก response 3. ใน Postman เลือก **Authorization** → **Bearer Token** แล้ววาง token 4. ทดสอบ `GET https://northwindbms.site.je/api/v1/products`

ถ้า host ส่ง HTML challenge แทน JSON ให้ผู้ให้บริการโฮสต์ยกเว้น `/api/v1/*` จาก Browser/JavaScript Challenge โดยยังคงการตรวจ JWT ของ API ไว้